
title: "Auditoría de Seguridad en Laboratorio de Red"

subtitle: "Informe Técnico de Pentesting — Entorno Aislado"

author: "Yensi Jesús González Nova"

date: "Agosto 2026"

\newpage

1. Resumen Ejecutivo

Se realizó una auditoría de seguridad sobre un laboratorio virtual aislado compuesto por una máquina objetivo (Metasploitable 2) en la red **10.99.99.0/24**. El objetivo fue identificar servicios expuestos, vulnerabilidades críticas y validar su explotación de forma controlada.

****Resultado:**** Se identificaron 2 vulnerabilidades críticas que permiten acceso remoto con privilegios de administrador (**root**), comprometiendo la confidencialidad, integridad y disponibilidad del activo.

| Severidad | Cantidad |

|-----|-----|

| Crítica | 2 |

| Alta | 0 |

| Media | 0 |

| Baja | 0 |

2. Alcance y Metodología

2.1 Alcance autorizado

- Red objetivo: 10.99.99.0/24
- Activo en alcance: 10.99.99.20 (Metasploitable 2)
- Entorno: laboratorio virtualizado aislado (VMware, red host-only)
- Fuera de alcance: redes de producción, sistemas de terceros

2.2 Metodología aplicada

1. Reconocimiento y descubrimiento de activos
2. Enumeración de servicios y versiones
3. Detección de vulnerabilidades (NSE Scripts)
4. Validación controlada y explotación
5. Documentación y remediación

Marco de referencia: fases de pentesting estándar (Reconnaissance, Scanning, Exploitation, Reporting).

2.3 Herramientas utilizadas

Herramienta	Uso
-------------	-----

-----	-----
-------	-------

Nmap	Descubrimiento, enumeración, NSE scripts
------	--

Wireshark / tcpdump	Captura y análisis de tráfico
---------------------	-------------------------------

Metasploit Framework	Explotación controlada
----------------------	------------------------

Netcat	Validación manual de servicios
--------	--------------------------------

3. Activos Identificados

IP	Sistema	Rol	Estado
----	---------	-----	--------

----	-----	-----	-----
------	-------	-------	-------

10.99.99.10	Kali Linux	Máquina auditora	Activo
-------------	------------	------------------	--------

10.99.99.20	Metasploitable 2	Objetivo	Activo
-------------	------------------	----------	--------

4. Hallazgos

4.1 Resumen de hallazgos

ID	Servicio	Vulnerabilidad	Severidad
----	----------	----------------	-----------

----	-----	-----	-----
------	-------	-------	-------

VUL-01	FTP (21/tcp)	Backdoor vsftpd 2.3.4	Crítica
--------	--------------	-----------------------	---------

VUL-02	SMB (445/tcp)	Samba usermap_script	Crítica
--------	---------------	----------------------	---------

4.2 Detalle de hallazgos

VUL-01: Backdoor en vsftpd 2.3.4

- **Servicio:** FTP — puerto 21/tcp

- **Versión:** vsftpd 2.3.4

- **Severidad:** Crítica
- **Descripción:** La versión 2.3.4 de vsftpd contiene una puerta trasera que se activa al enviar credenciales con una secuencia específica, abriendo una shell en el puerto 6200.
- **Validación:** Confirmado mediante banner grabbing y script NSE `ftp-vsftpd-backdoor`. Explotación manual verificada con acceso root.
- **Impacto:** Acceso remoto completo con privilegios de administrador, compromiso total de identidades locales y recursos.
- **Remediación:** Actualizar vsftpd a una versión soportada y aplicar mínimo privilegio en cuentas de servicio.

VUL-02: Ejecución remota en Samba (usermap_script)

- **Servicio:** SMB — puerto 445/tcp
- **Versión:** Samba 3.0.20
- **Severidad:** Crítica
- **Descripción:** Configuración vulnerable que permite ejecución remota de comandos mediante el parámetro `username map script`.
- **Validación:** Explotación verificada con Metasploit obteniendo acceso root.
- **Impacto:** Ejecución arbitraria de código, compromiso de recursos compartidos e identidades.
- **Remediación:** Actualizar Samba y deshabilitar directivas inseguras de mapeo de usuarios.

5. Análisis de Impacto (Enfoque IAM)

Ambos hallazgos permiten obtener privilegios de administrador, lo que implica:

- Compromiso total de identidades locales (`/etc/passwd`, `/etc/shadow`).
- Acceso sin control a recursos compartidos SMB/NFS.
- Incumplimiento del principio de mínimo privilegio.
- Riesgo de movimiento lateral si el activo estuviera conectado a otros segmentos.

6. Remediación Priorizada

| ID | Acción | Prioridad |

|----|-----|-----|

| REC-01 | Actualizar vsftpd a versión soportada | Crítica |

| REC-02 | Actualizar Samba y deshabilitar usermap script | Crítica |

| REC-03 | Segmentar y filtrar puertos en firewall | Alta |

| REC-04 | Aplicar mínimo privilegio en cuentas de servicio | Alta |

| REC-05 | Monitorizar accesos anómalos (IDS/SIEM) | Media |

7. Anexos

- Evidencias de escaneos Nmap
- Capturas de validación y explotación
- Capturas de tráfico (PCAP analizadas)

8. Declaración de Ética Profesional

Esta auditoría se realizó exclusivamente en un laboratorio virtual aislado y autorizado. No se atacaron sistemas reales ni de terceros. La información aquí contenida tiene fines formativos y de demostración metodológica.